SINGAPORE INSTITUTE OF TECHNOLOGY

Advanced Persistent Threats

Dr Vivek Balachandran

Vivek.B@SingaporeTech.edu.sg

Advanced Persistent Threats - Scope

- APTs refer to tools and techniques that can be used to launch an attack that cannot be stopped by conventional security mechanisms
- APT Attack Cycle
- APT Characteristics
- Real World Examples
- Current Scenarios





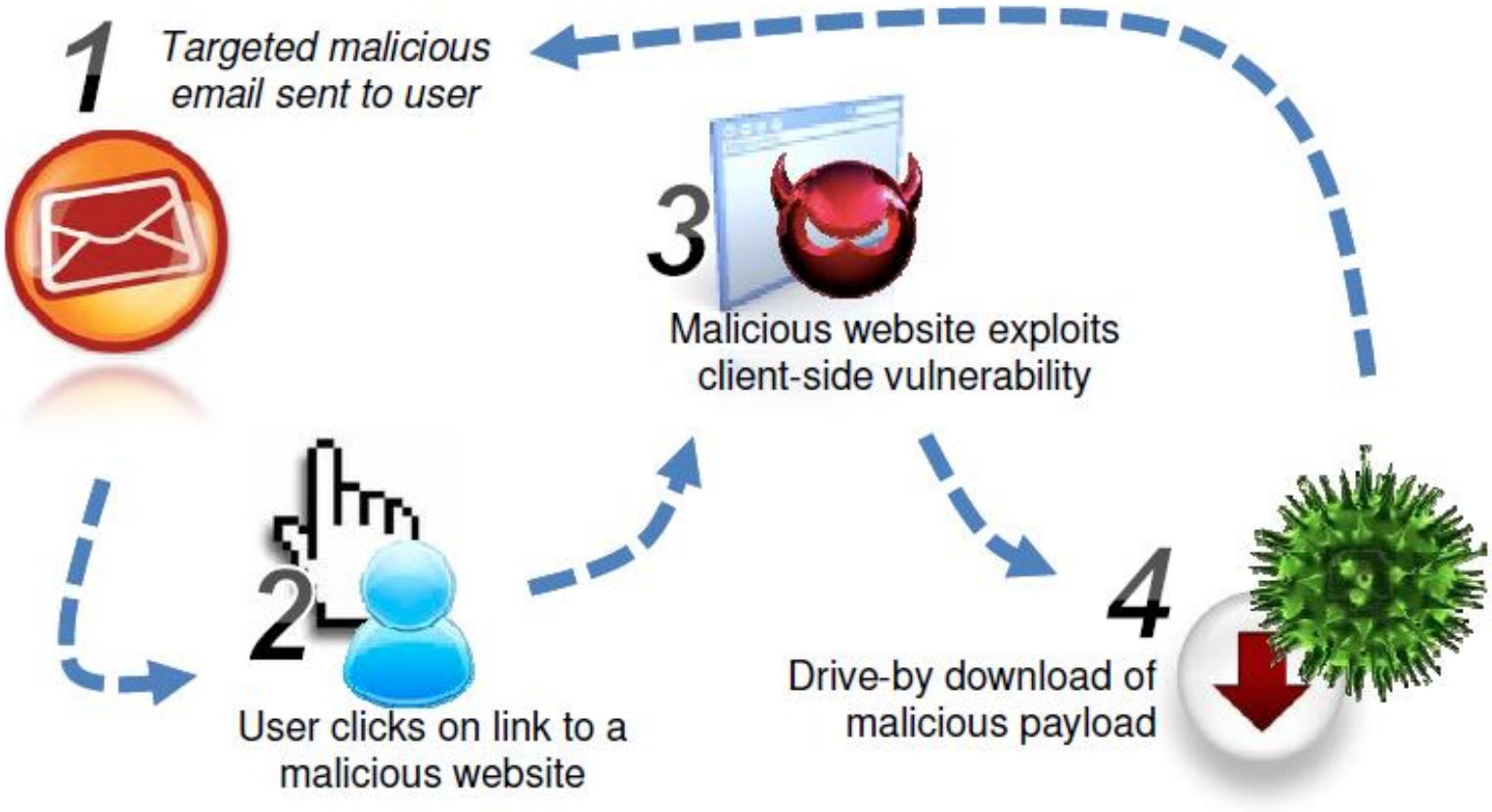
A Typical APT Attack Cycle

- An APT attack phase:
  - are gradual and incremental (extended and repetitive reconnaissance, scanning and enumeration)
  - Coordinated across attack points
  - Continuous strive for stealth (may make use of repetitive tracks covering attempts)
  - Will try multiple times using different methods (persistent)
  - C & C Server directs further attacks



- Cloud computing and BYODs increase target attack surface

A Phishing Attack Cycle



- Target user/subset of users determined (e.g. via social engineering)
- Repeated different email if first is ignored/deleted
- Downloaded malicious payload (e.g. backdoor)
- Stealth needs to be maintained so that phase 1 can be repeated

Spear Phishing

1 Spear phish attack exploits PC

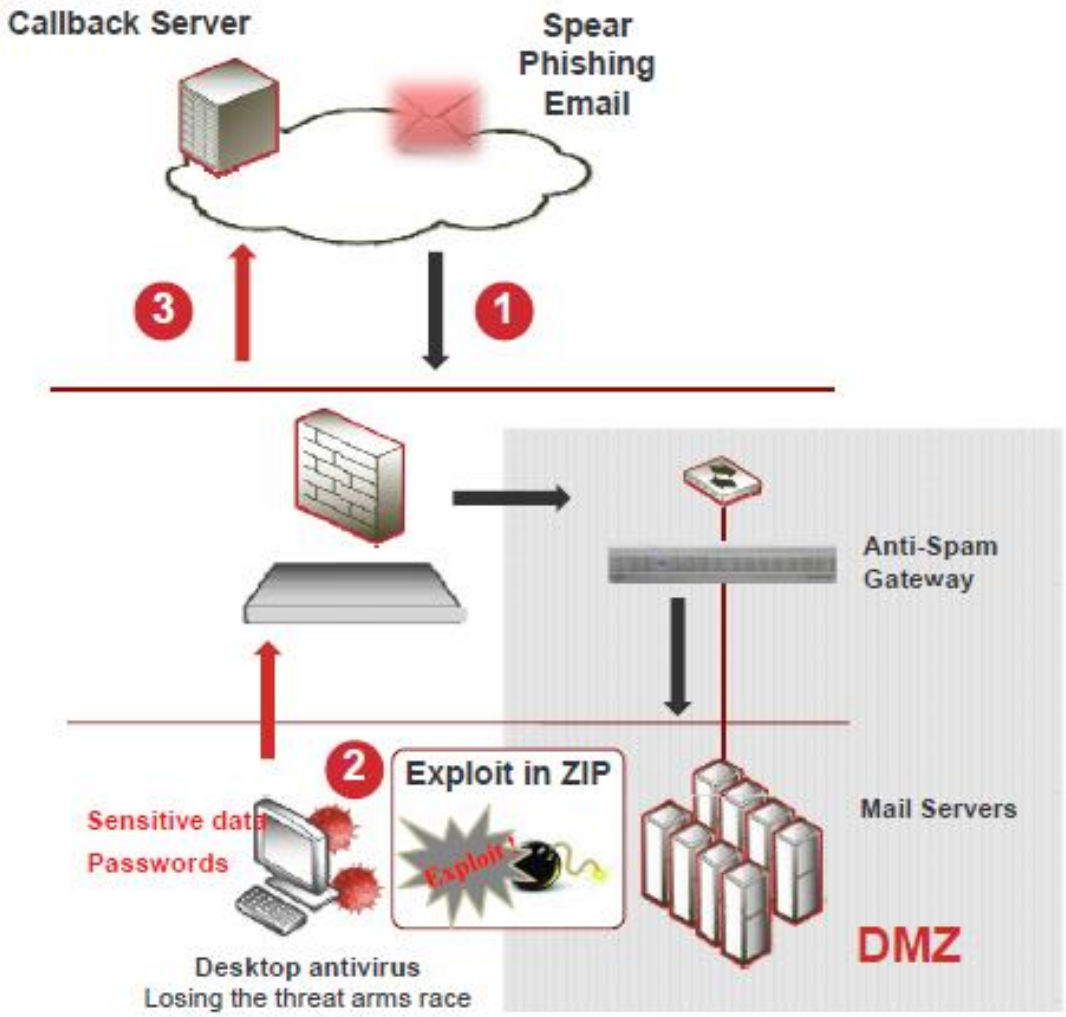
- More than 50% use malicious URLs
- Attachments: PDF, PPT, XLS and DOC
- Targeted mid- & high-level energy execs
- Also targeted Vendors (Investment Bankers, Oil & Gas Service companies)

2 Back door opened & lateral spread

- ZIP file on Windows 7
- Exploit code executed when ZIP opened

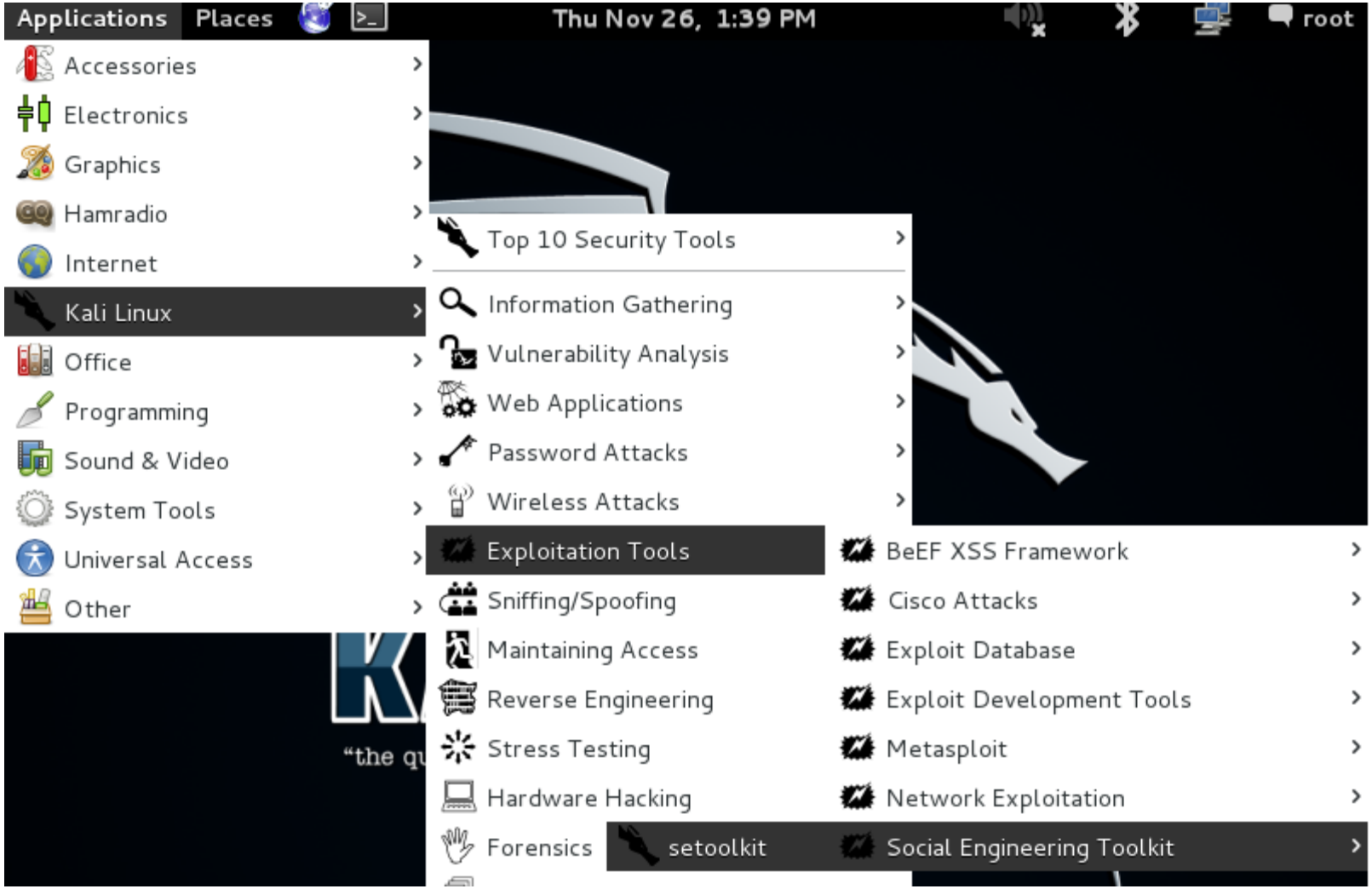
3 Second phase objects and callbacks linked to initial exploit

- Callbacks related to RSA intrusion
- Data exfiltration commences



Spear Phishing Attack Demo

- Install Kali Linux in VMware
- Select the Social Engineering Toolkit



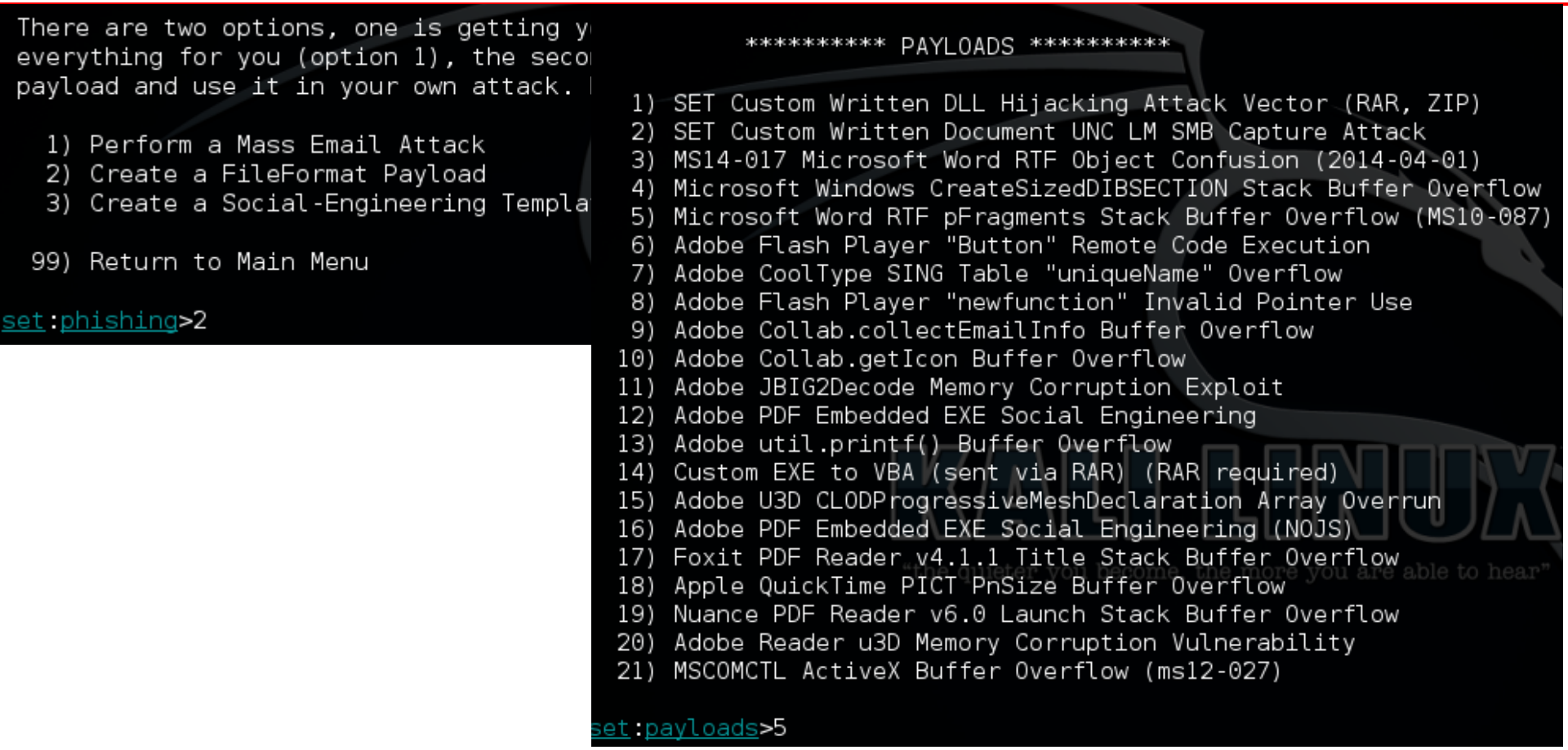
Spear Phishing Attack Demo





- Select the Social-Engineering Attacks
- Select Spear-Phishing Attack Vectors

Spear Phishing Attack Demo



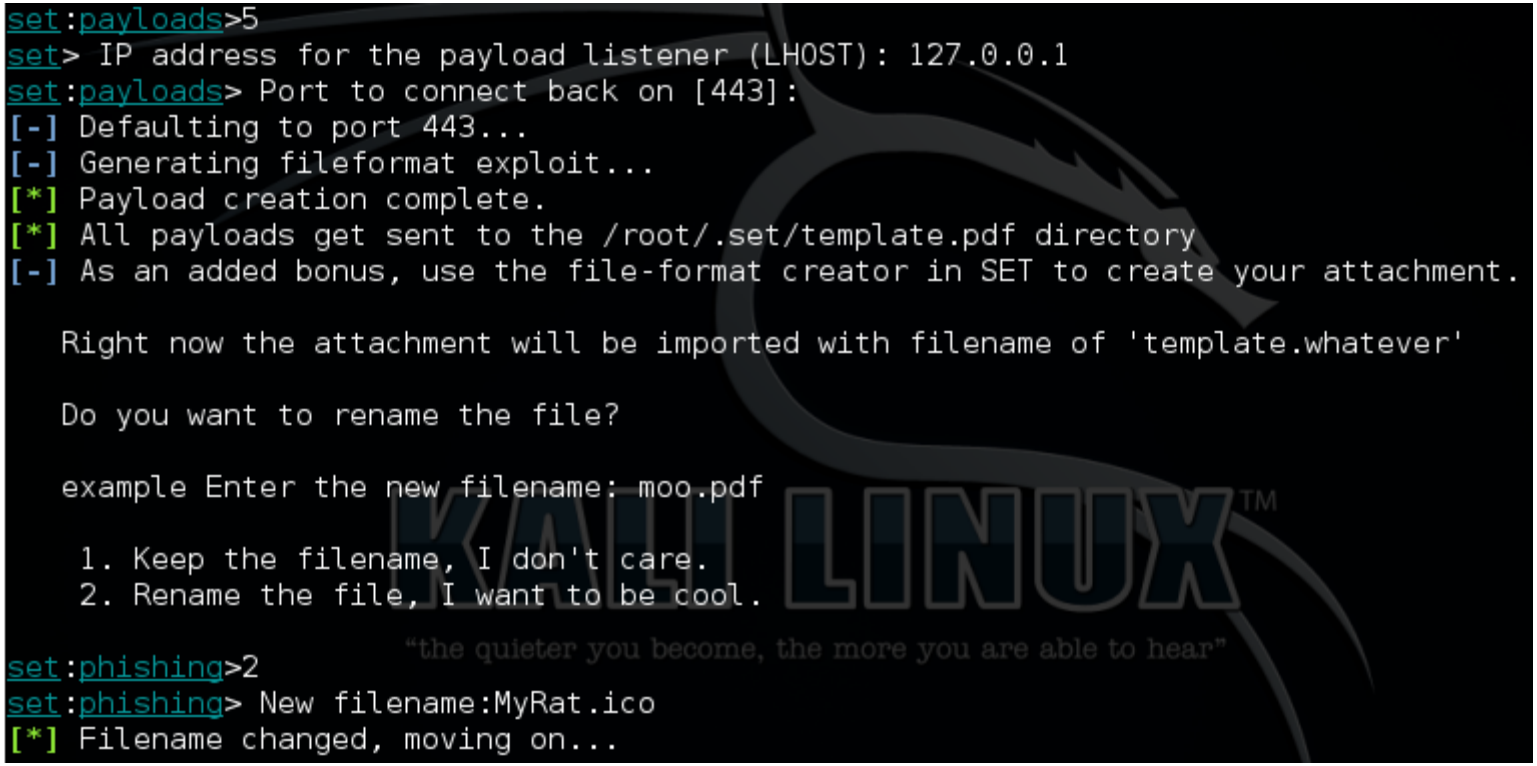
- Select 2 to create a FileFormat payload
- Type 5 and press enter
- This will create a Word document that will overflow a buffer and enable us to put a listener or rootkit on the victim's machine

Spear Phishing Attack Demo



- Our next step is to decide what type of listener (aka rootkit, aka payload) we want to leave on the victim system
- Type 5 and press enter
- We try to get the Metasploit meterpreter on the victim's machine

Spear Phishing Attack Demo



- After the payload listener's IP and port are entered, SET creates the malicious file, 'template.rtf'
- Rename the file (optional)

Spear Phishing Attack Demo

```
   What do you want to do:

   1.  E-Mail Attack Single Email Address
   2.  E-Mail Attack Mass Mailer

   99. Return to main menu.

set:phishing>1

   Do you want to use a predefined template or craft
   a one time email template.

   1. Pre-Defined Template
   2. One-Time Use Email Template

set:phishing>2
set:phishing> Subject of the email:Pwned Another Day
set:phishing> Send the message as html or plain? 'h' or 'p' [p]:p
set:phishing> Enter the body of the message, hit return for a new line. Control+c when
finished:Dear Enemy,
Next line of the body: Trust this email finds you well.
Next line of the body: I'm sending you a gift to end our feud.
Next line of the body: Hope you have the ***** to open it.
Next line of the body: Best Regards,
Next line of the body: Bond 007
```

- After the payload listener's IP and port are entered, SET creates the malicious file (may be stopped by Google)
- Rename the file (optional), end email with Ctrl-C

The Targeted Attack Model

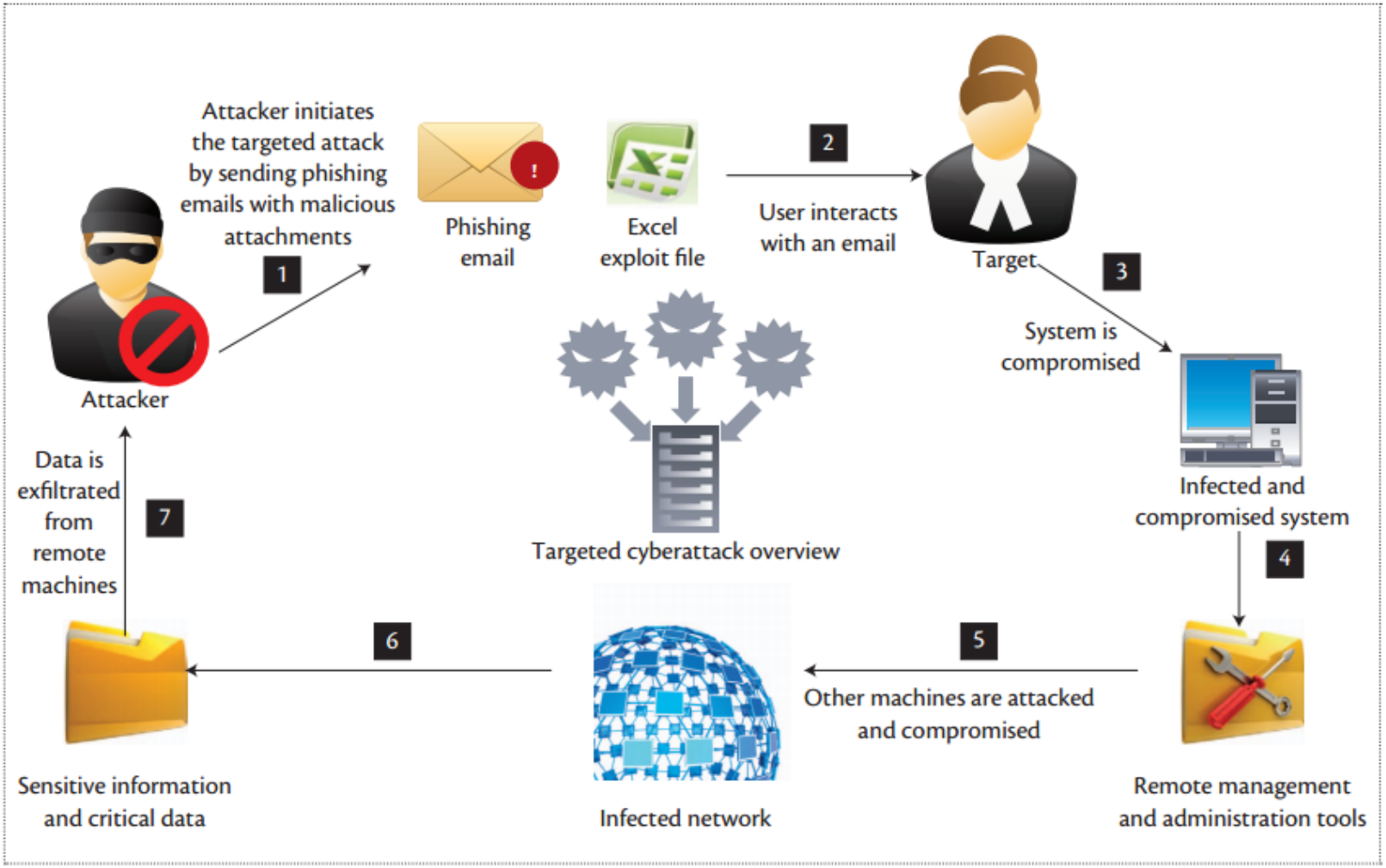


Figure 1. A targeted attack in action. A phishing email carries exploitation code as part of its attachments (DOC, PDF, XLS), similar to how a recent attack compromised the RSA organization.

The Targeted Attack Model

- **Intelligence Gathering**
  - Open source intelligence (OSINT) gathering, which is the process of collecting intelligence from public or openly available resources
  - In passive mode, no actual interaction (traffic) takes place with the target
  - In semi-passive mode, attackers use generic information-gathering methods that generate normal traffic without suspicion, such as DNS queries or WHOIS lookups
- Threat Modeling
  - Map the target environment and categorize assets based on their importance and value into primary and secondary targets
  - Assessing risks and threats to determine which domains are most likely to reveal the attack and which domains might invite retaliation

RSA Attack Example and Analysis



Open Letter to RSA Customers

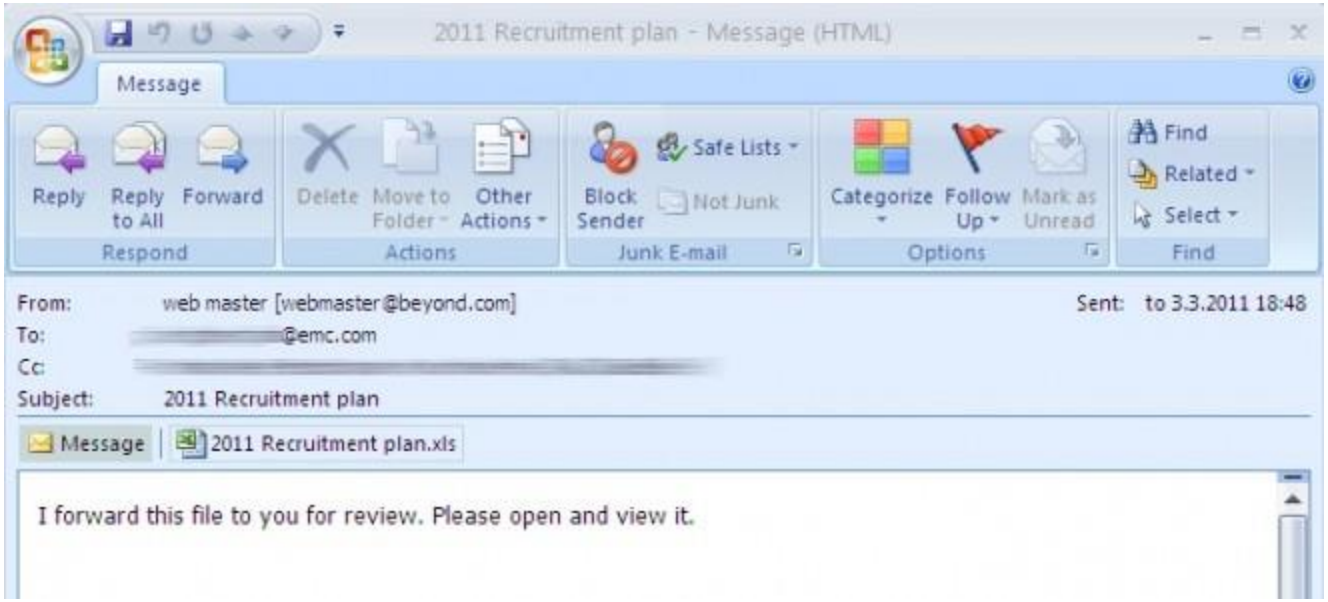
Arthur W. Coviello, Jr.

Like any large company, EMC experiences and successfully repels multiple cyber attacks on its IT infrastructure every day. Recently, our security systems identified an extremely sophisticated cyber attack in progress being mounted against RSA. We took a variety of aggressive measures against the threat to protect our business and our customers, including further hardening of our IT infrastructure. We also immediately began an extensive investigation of the attack and are working closely with the appropriate authorities.

Our investigation has led us to believe that the attack is in the category of an Advanced Persistent Threat (APT). Our investigation also revealed that the attack resulted in certain information being extracted from RSA's systems. Some of that information is specifically related to RSA's

- March 2011, RSA had a data breach
  - Attacker stole information which affected some 40 million two-factor authentication tokens
  - Devices are used in private industry and government agencies
  - Produces a 6 digit number every 60 seconds

RSA Attack Example and Analysis



- Spear Phishing with Backdoor APT
  - Attackers sent two different targeted phishing emails to four workers at RSA's parent company EMC
  - Emails contained a malicious attachment that was identified in the subject line as "2011 Recruitment plan.xls"
  - When one of the four recipients clicked on the attachment, the attachment installed a backdoor (Poison Ivy)

APT Attack Characteristics

- APTs are:
  - Targeted, low-profile attacks
  - Extremely stealthy
  - Highly motivated and determined
  - Well-financed
  - Coordinated across attack points
  - Very low to zero target down time



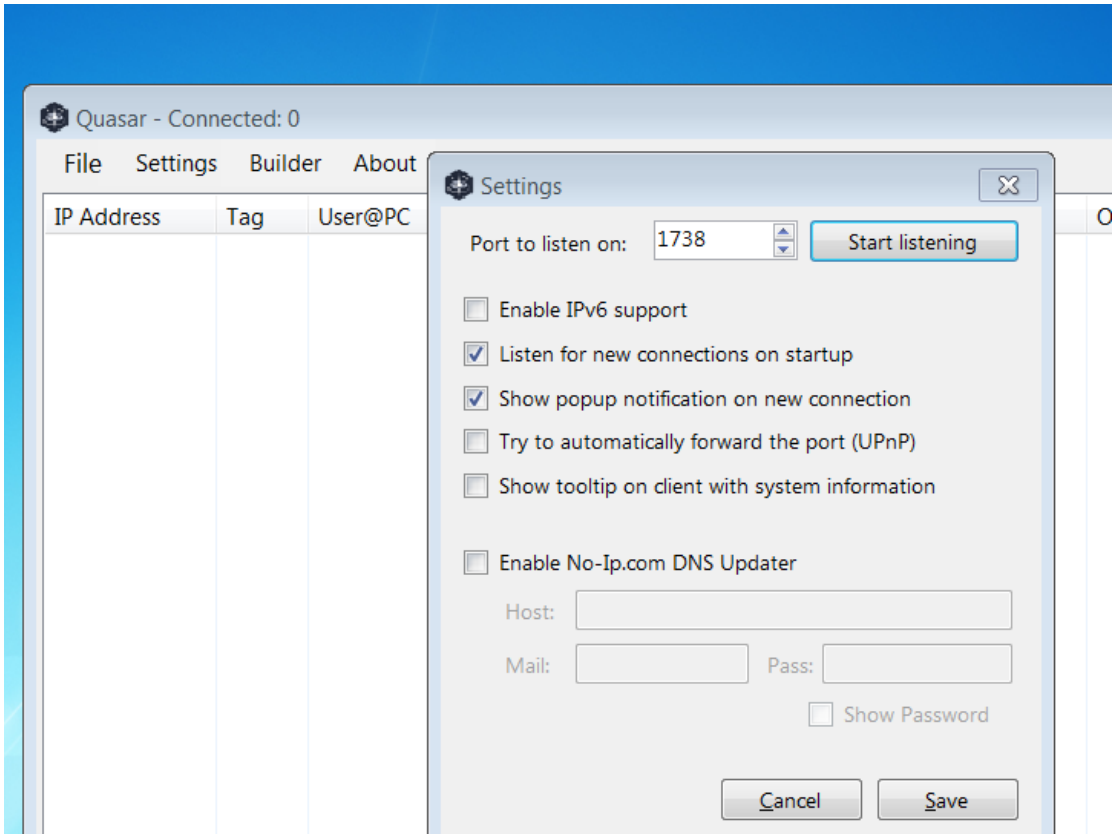
- Many organizations operate for years without knowing that they have been breached!

Quasar RAT

- Download from https://github.com/quasar/Quasar/releases/tag/v1.4.0
- Show remote management and administration in the targeted attack model
- Your platform is the C & C server
- Disable chrome protection to download the latest version from GitHub

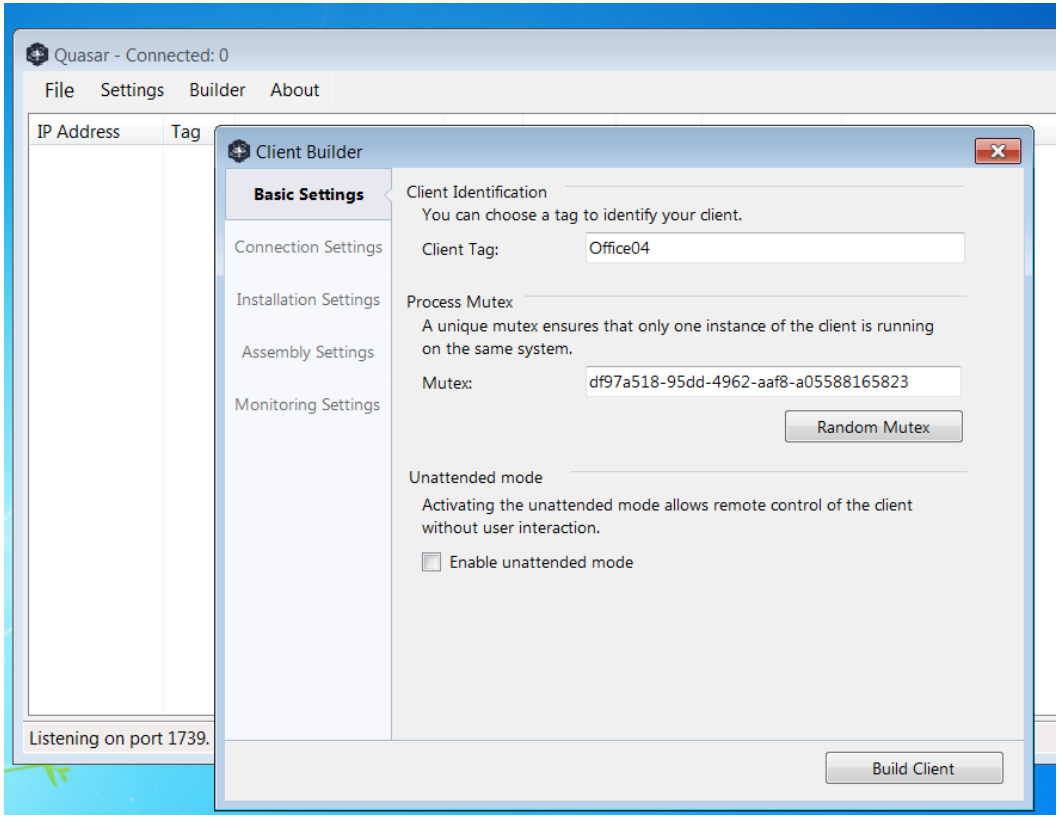
Quasar RAT

- Goto Settings
- Decide on the port to listen to
- Start listening
  - Any connection to the port
- Next step
  - Build the client executable



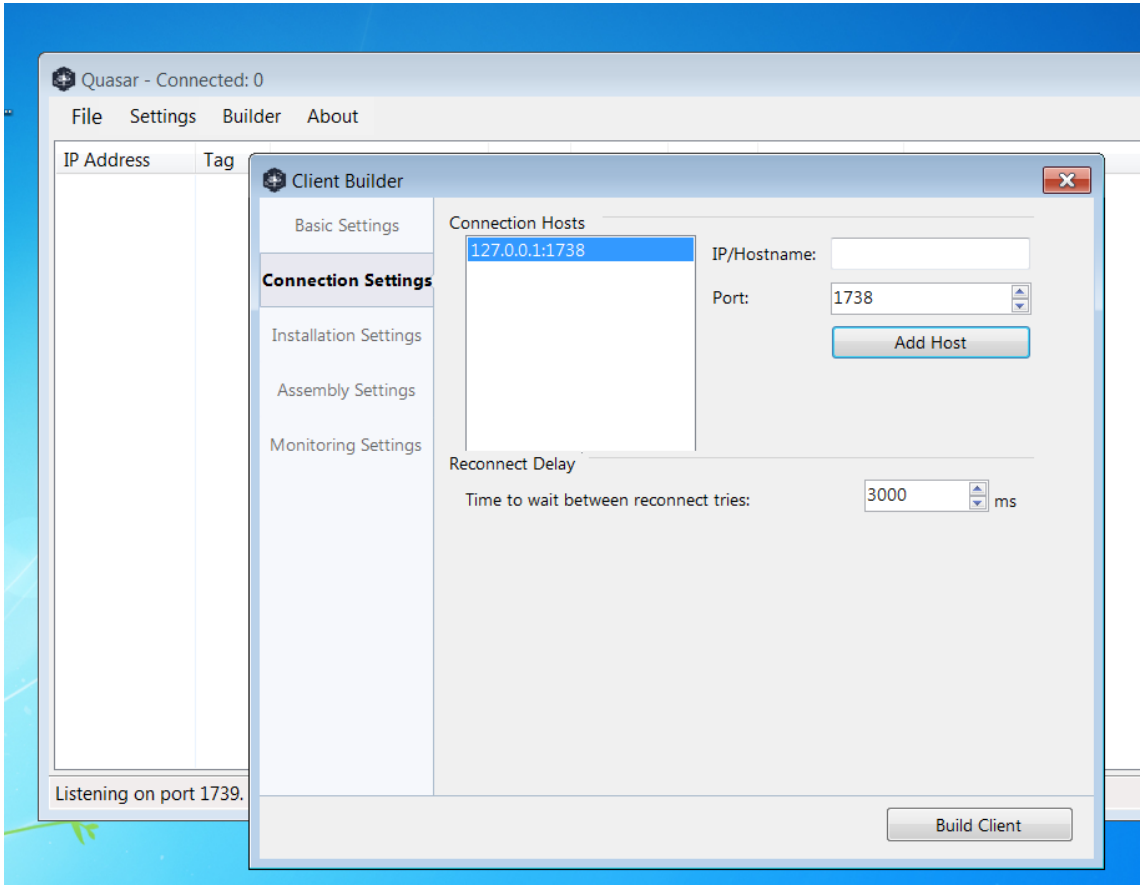
Quasar RAT

- Goto Builder
- Basic settings
- Name the client tag
- Mutex
  - Ensures only one instance runs on a system



Quasar RAT

- Connection settings
- Specify Attack machine's
  - Port number
  - IP address
- Remember to port forward
- Next step
  - Other settings

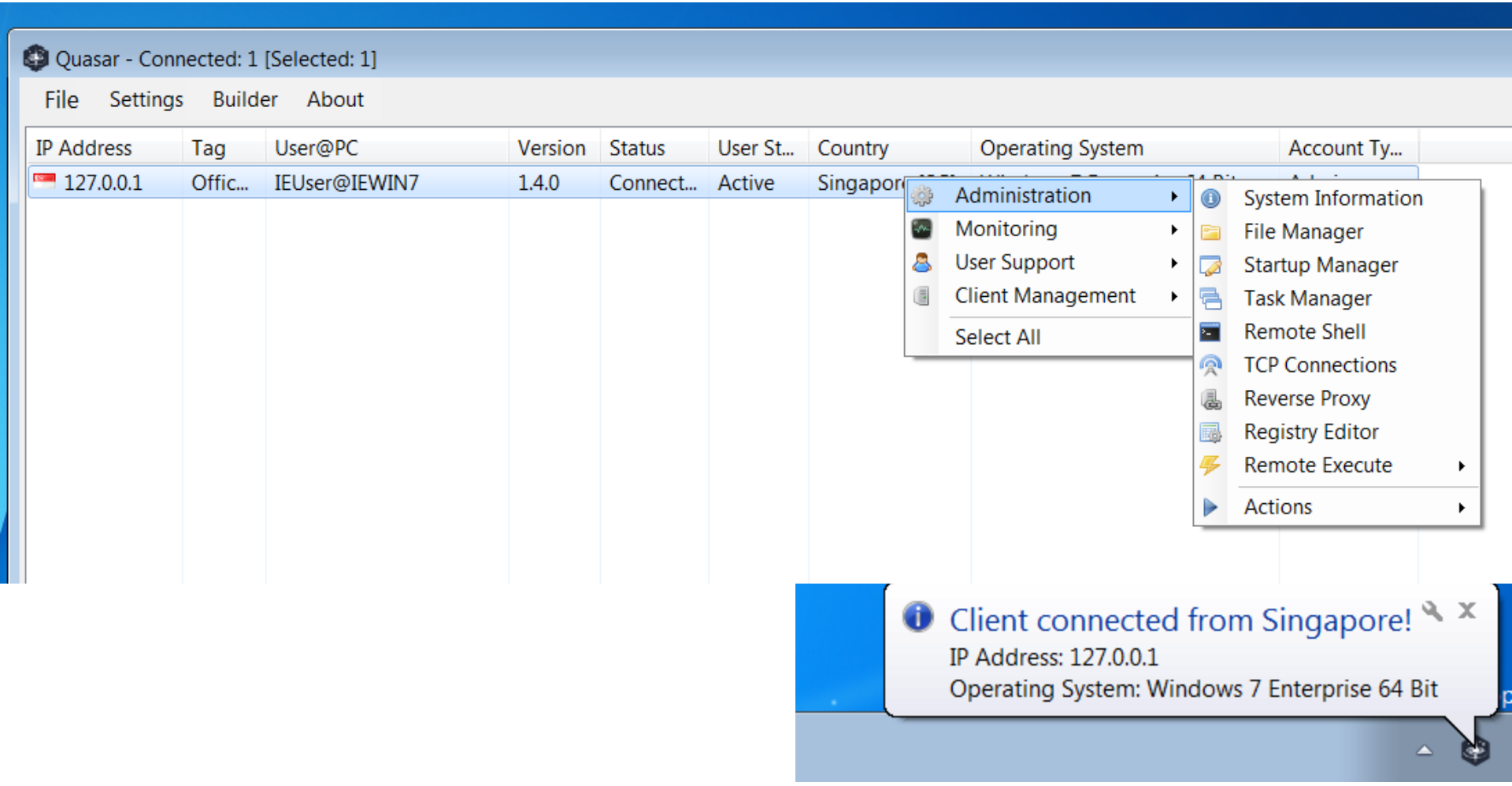


Quasar

- Installation Settings
  - Where to install the RAT on client's machine
  - Installation and running options
- Assembly Settings
  - How do you want the file to look like
- Monitor Settings
  - Keyboard logging
- Build the client
  - Install the executable in the victim machine
  - Phishing email, USB dropping etc..

Quasar RAT

- Gives you remote access



Advanced Persistent Threats

SINGAPORE INSTITUTE OF TECHNOLOGY

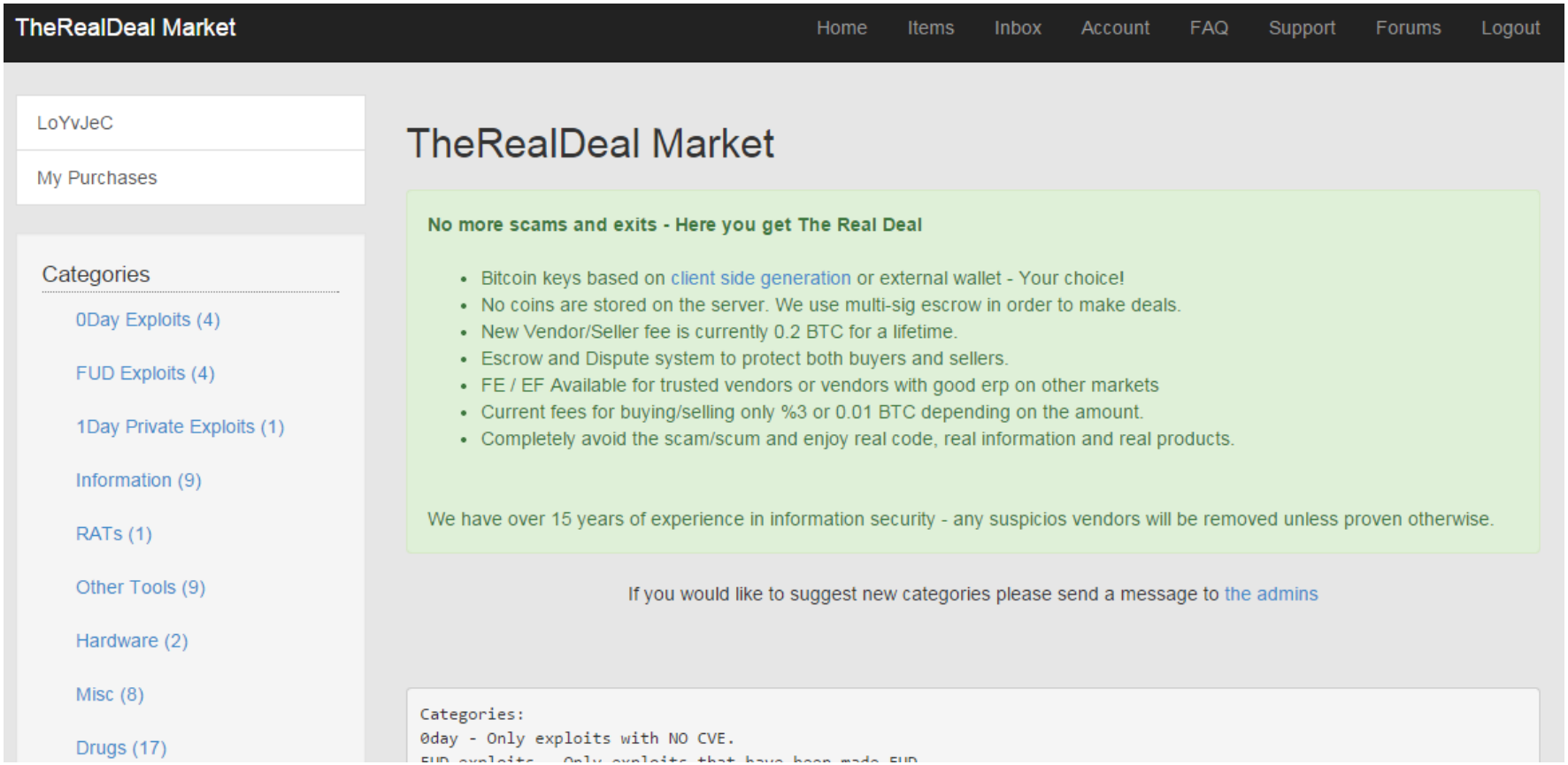
- **Advanced**
  - Attacker adapts to defenders' efforts
  - Can develop or buy Zero-Day exploits
  - Higher level of stealth employed
- **Persistent**
  - Attacks are objective and specific
  - Will continue until goal is reached
  - Intent to maintain long term connectivity
- **Threats**
  - Entity or entities behind the attack
  - Strong financial and human (expertise) resources

Anatomy of an APT Attack



- Malware Infection Frameworks
- Browser Exploit Packs and Glype Proxies
- RATs and Rootkits
- Morphing and Obfuscation Toolkits
- Interface with an Underground Market

Underground Market



- TheRealDeal Market (http://trdealmgn4uvm42g.onion) appeared in March 2015 and is focused on commercialization of zero-day exploits
- The marketplace is hosted on the popular TOR network (https://www.torproject.org/)

APT Targets



- ✓ Banking, Finance, & Insurance
- ✓ Petrochemical Energy, & Transport
- ✓ Media



- ✓ ISP - Internet Service Providers
- ✓ NSP - Network Service Providers
- ✓ Mobile & Telco Operators



- ✓ Defense
- ✓ CERT/CSIRT
- ✓ Intelligence
- ✓ Utilities

Shadow Force APT - DLL Hijacking



TREND MICRO

TrendLabs SECURITY INTELLIGENCE Blog

SECURITY NEWS DIRECT FROM THREAT DEFENSE EXPERTS

Home | Categories

Home » Malware » Shadow Force Uses DLL Hijacking, Targets South Korean Company

Shadow Force Uses DLL Hijacking, Targets South Korean Company

Posted on: September 9, 2015 at 1:00 am **Posted in:** Malware, Targeted Attacks
Author: Dove Chiu (Threat Researcher)

SHADOW FORCE USES DLL HIJACKING, TARGETS SOUTH KOREAN COMPANY

2015-09-09

advancedpersistent apt, Recently Read, Saved for Later

Leave a comment

What sort of interest would a businessman have in a news agency? That was the question that arose from our recent investigation on an attack that appears to target a media agency in South Korea. Shadow Force is a new backdoor that replaces a DLL called by a particular Windows service. Once that backdoor is open, the attacker [...]

from TrendLabs Security Intelligence Blog http://ift.tt/1icsbJX

DLL Hijacking Details

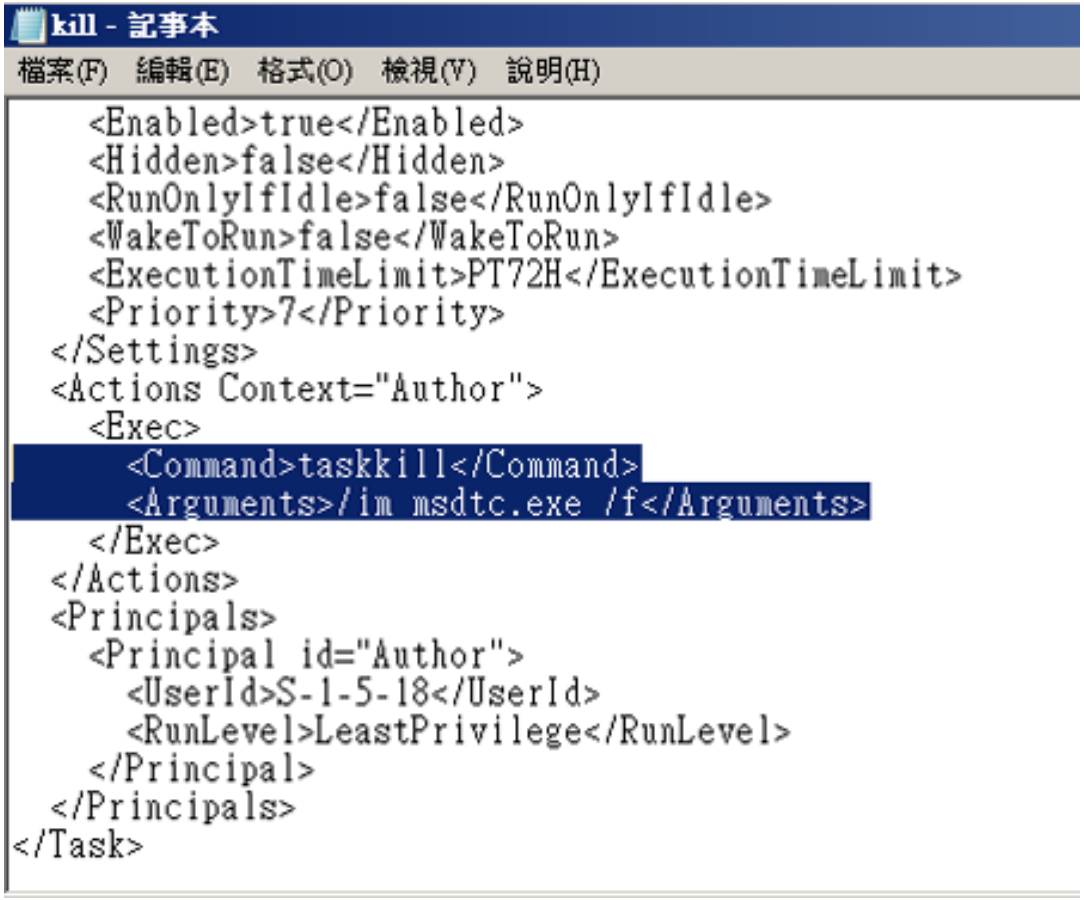
- Windows has a search path for DLLs (**Dynamic-Link Library Search Order**) similar to $PATH for executables
- Attacker's objective is merely to figure out where to place a hostile DLL in the earlier part of the search path
- Rename the hostile DLL as a legitimate system DLL
- When Windows searches for the legitimate DLL, it will locate the hostile one and use this instead

Actual Shadow Force Attack



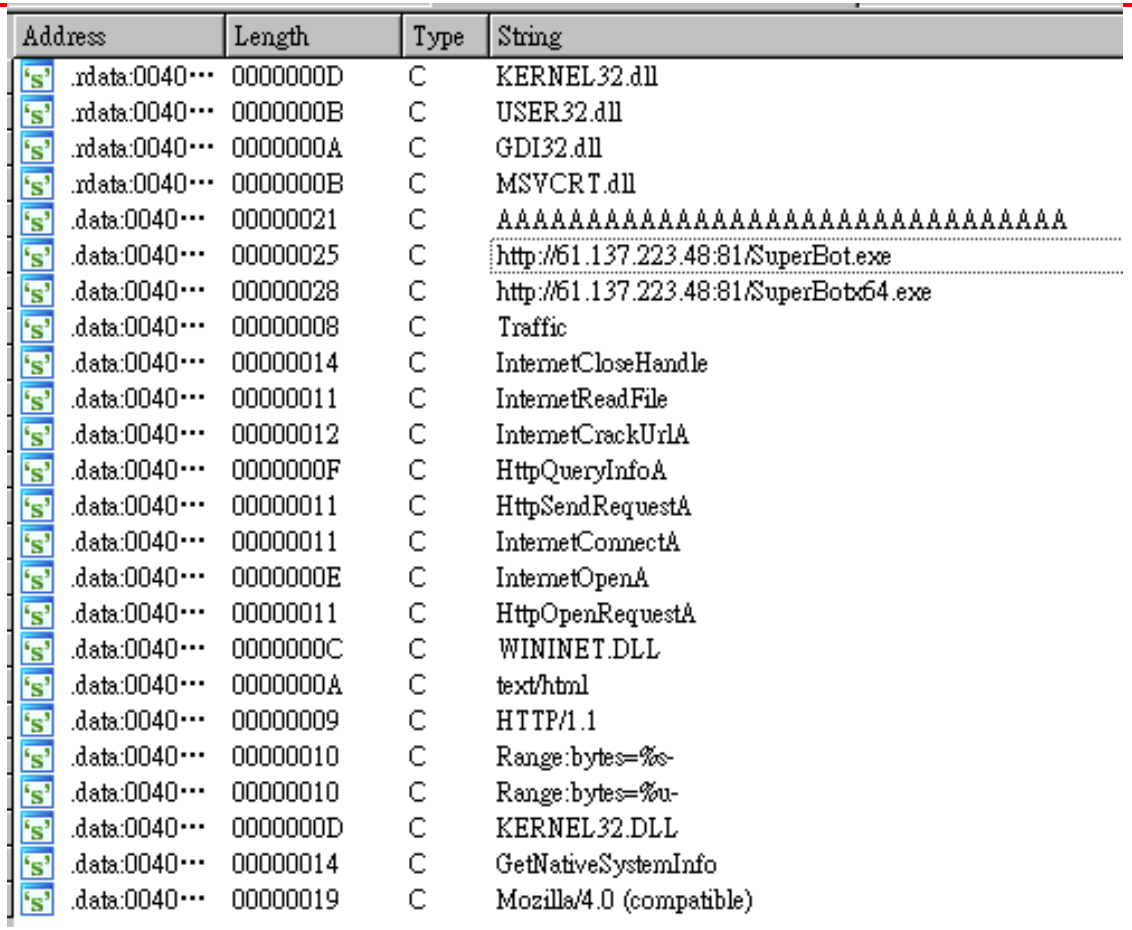
- Windows OS starts the Microsoft Distributed Transaction Coordinator (MSDTC) service, which coordinates transactions that span multiple resource managers, such as databases, message queues, and file systems. When the MSDTC service starts, it will search the registry
- Specifically, the MTxOCI component in MSDTC service searches for three DLLs: oci.dll, SQLLib80.dll, and xa80.dll. oci.dll is from an Oracle installation
- Attacker creates a backdoor component , renames it to oci.dll, and places it in %SystemRoot%\system32\

Actual Shadow Force Attack



- Attacker uses a remote job command to kill the MSDTC service (**taskkill /im msdtc.exe /f**), causing MSDTC to reload itself
- Reloaded MSDTC now looks for and finds the hostile oci.dll. Calling this DLL opens up Shadow Force

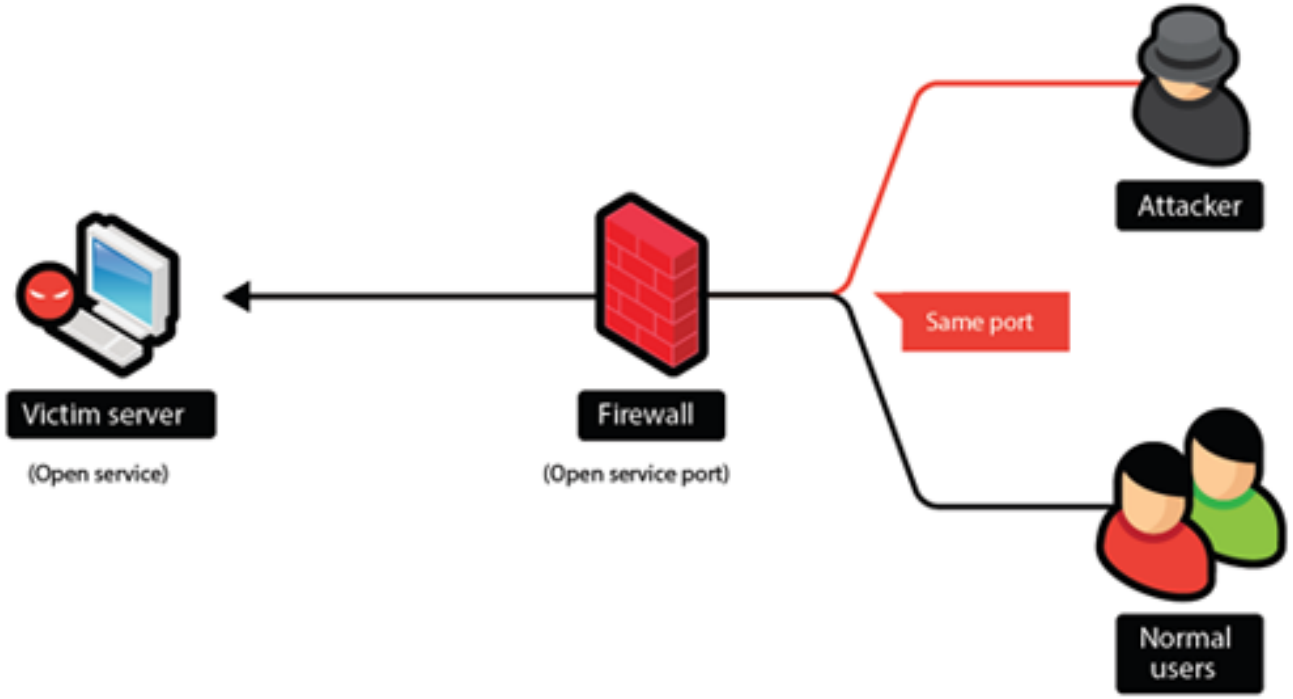
Actual Shadow Force Attack



Address	Length	Type	String
.rdata:0040…	0000000D	C	KERNEL32.dll
.rdata:0040…	0000000B	C	USER32.dll
.rdata:0040…	0000000A	C	GDI32.dll
.rdata:0040…	0000000B	C	MSVCRT.dll
.data:0040…	00000021	C	AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
.data:0040…	00000025	C	http://61.137.223.48:81/SuperBot.exe
.data:0040…	00000028	C	http://61.137.223.48:81/SuperBotx64.exe
.data:0040…	00000008	C	Traffic
.data:0040…	00000014	C	InternetCloseHandle
.data:0040…	00000011	C	InternetReadFile
.data:0040…	00000012	C	InternetCrackUrlA
.data:0040…	0000000F	C	HttpQueryInfoA
.data:0040…	00000011	C	HttpSendRequestA
.data:0040…	00000011	C	InternetConnectA
.data:0040…	0000000E	C	InternetOpenA
.data:0040…	00000011	C	HttpOpenRequestA
.data:0040…	0000000C	C	WININET.DLL
.data:0040…	0000000A	C	text/html
.data:0040…	00000009	C	HTTP/1.1
.data:0040…	00000010	C	Range:bytes=%s-
.data:0040…	00000010	C	Range:bytes=%u-
.data:0040…	0000000D	C	KERNEL32.DLL
.data:0040…	00000014	C	GetNativeSystemInfo
.data:0040…	00000019	C	Mozilla/4.0 (compatible)

Shadow Force has several different variations, both in DLL and EXE formats and in 32-bit or 64-bit implementations. The type of variation depends on *installe.exe*, the file that downloads and installs Shadow Force on the computer. If *install.exe* runs in 32-bit mode, it will download *SuperBot.exe*. Otherwise, it will download *SuperBotx64.exe*.

Actual Shadow Force Attack



The Shadow Force .exe version will connect to a C&C server (irc[.]itembuy[.]org) like a normal IRC bot. The DLL version of Shadow Force downloads and installs the file *npf.sys*. The *npf.sys file* (downloaded by Shadow Force as a part of its function) comes from the open source project Wireshark, a well-known network protocol analyzer. Therefore, the *npf.sys* has a valid signature and can be loaded in Windows, to be used in capturing network packets.

Salt Typhoon

- Alleged attack on US ISP's
- Attack grp – Salt Typhoon, FamousSparrow, GhostEmperor



Dual Protection Strategies

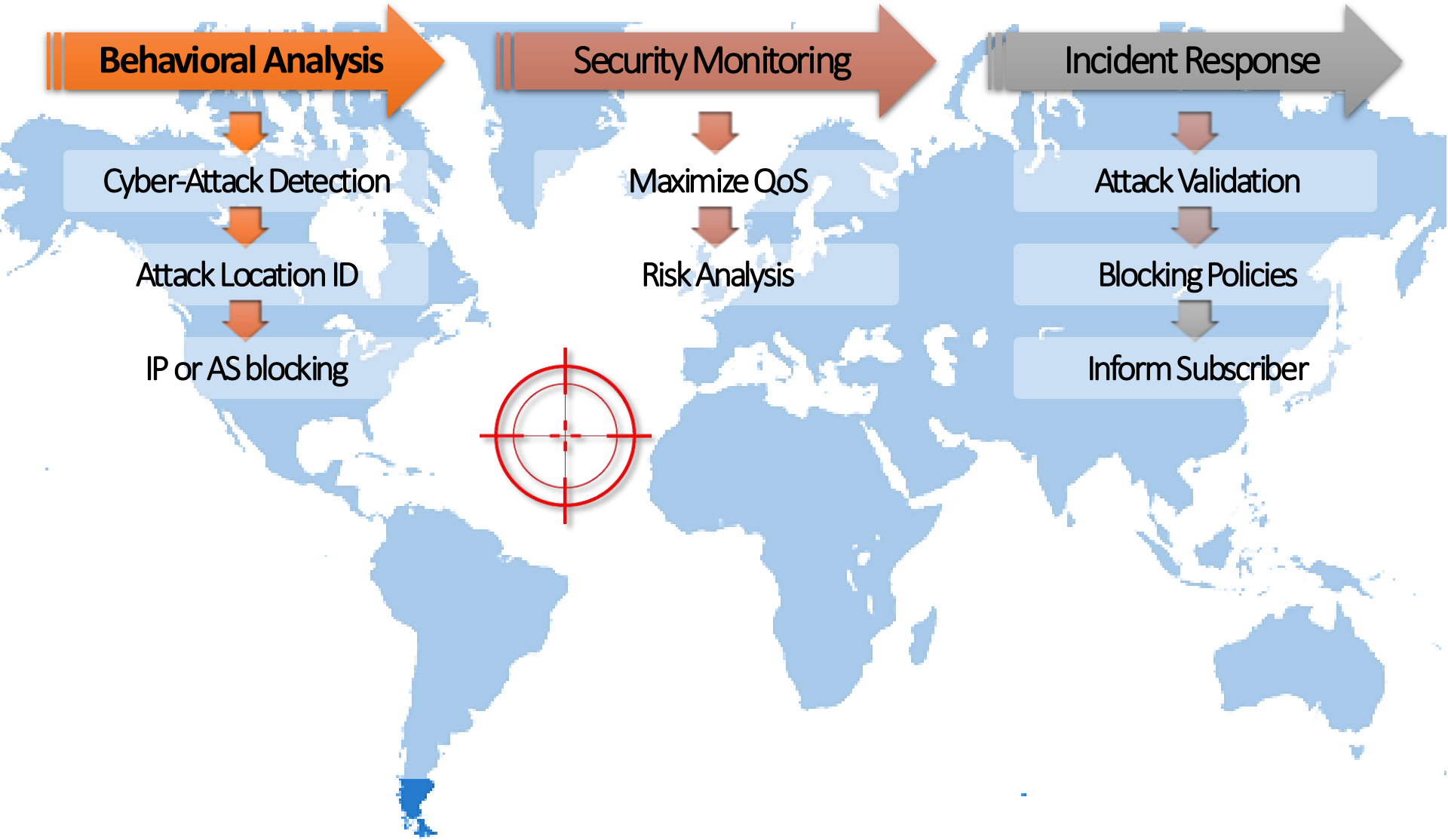
- **Boundary Protection**
  - Primary Consideration: ***Penetration Resistance***
  - Adversary Location: ***Outside the Defensive Perimeter***
  - Objective: ***Repelling the Attack***

- **Agile Defense**
  - Primary Consideration: ***Information System Resilience***
  - Adversary Location: ***Inside the Defensive Perimeter***
  - Objective: ***Operating while under Attack***

Agile Defense

- Boundary protection is a necessary but not sufficient condition for *Agile Defense*
- Examples of *Agile Defense* measures:
  - Compartmentalization and segregation of critical assets
  - Targeted allocation of security controls
  - Virtualization and obfuscation techniques
  - Encryption of data at rest
  - Reconstitution to known secure state after failure

Preventive Solutions



Summary

- APT Attack Cycle and Characteristics
  - Extended reconnaissance, extreme stealth, persistence
- Real World Examples
  - RSA – Spear Phishing
  - Shadow Force – DLL Hijacking
- Demos
  - Spear Phishing
  - RAT